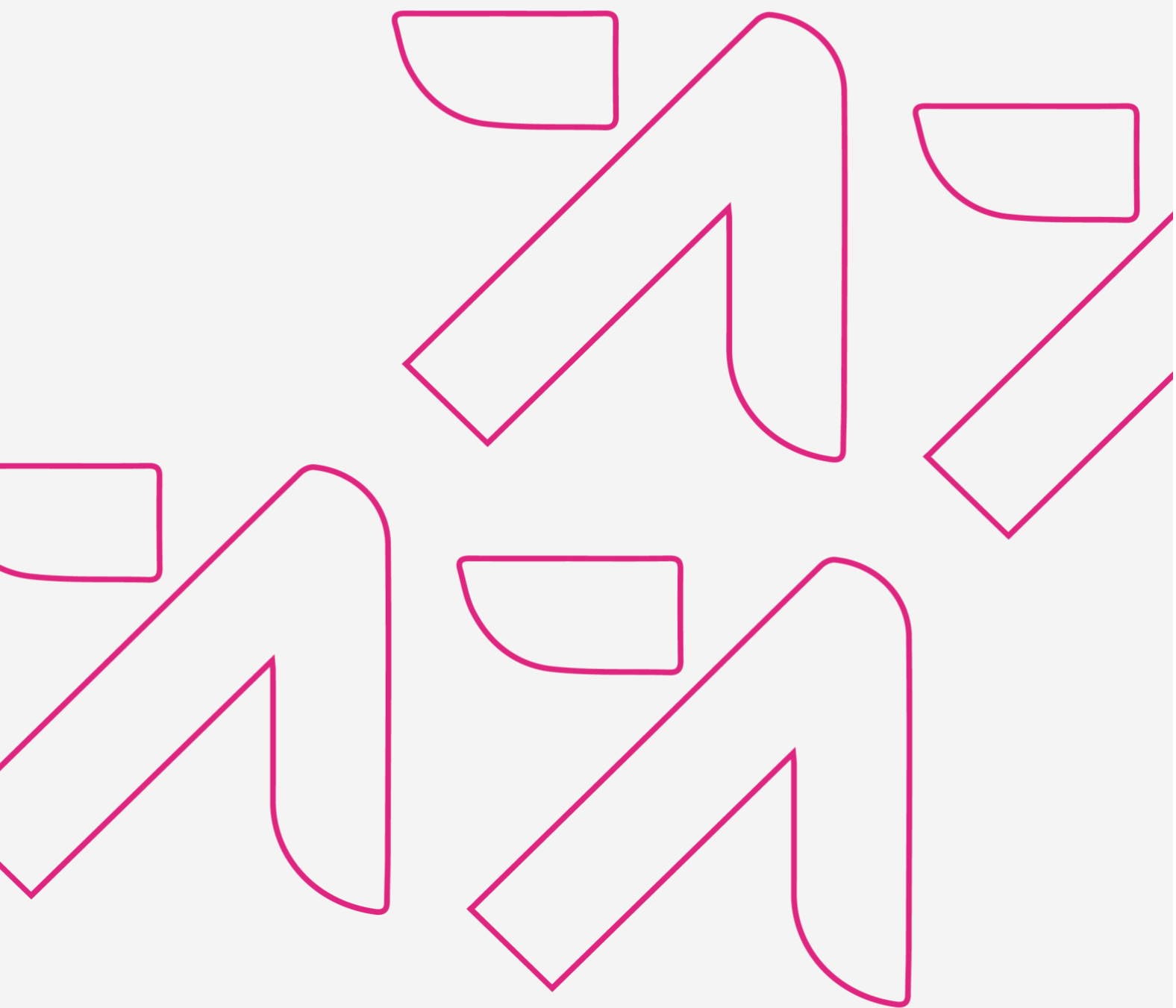




Máster de

Ciberseguridad Hacking Ético

[Módulo Incidentes de Ciberseguridad]

Curso académico 2026/2027 - Edición Presencial

Tema 10. Notificación y comunicación de incidentes de ciberseguridad

Encaje en el curso 2026/2027: tema 10 del temario oficial, dentro del RA5. Los apartados 2 a 4 desarrollan la notificación en tiempo y forma a los organismos competentes, que es lo que piden los criterios del RA5 y el temario oficial apenas trata.

1. Por qué notificar

- **Porque es obligatorio** en muchos casos, con plazos cortos y sanciones si no se cumple.
- **Porque ayuda:** los equipos de respuesta nacionales aportan apoyo técnico e información sobre ataques similares.
- **Porque protege a otros:** un indicador compartido a tiempo evita víctimas.
- **Porque genera confianza:** ocultar un incidente que acaba saliendo a la luz daña más que el propio incidente.

2. A quién, cuándo y por qué

Destinatario	Cuándo	Plazo	Base
AEPD	Brecha de datos personales con riesgo para las personas	72 horas desde que se tiene constancia	RGPD, artículo 33
Personas afectadas	Si el riesgo para ellas es alto	Sin dilación indebida	RGPD, artículo 34
INCIBE-CERT	Empresas y ciudadanía; obligatorio para operadores sujetos a normativa específica	Según peligrosidad e impacto	Guía Nacional
CCN-CERT	Sector público y sistemas dentro del ENS	Según peligrosidad e impacto	ENS y Guía Nacional
CSIRT o autoridad competente	Entidades esenciales e importantes, ante incidentes significativos	Alerta temprana en 24 h, notificación en 72 h, informe final en un mes	Directiva NIS2
Fuerzas y cuerpos de seguridad	Cuando hay indicios de delito	Cuanto antes	Denuncia
Clientes y proveedores	Si les afecta o lo exige el contrato	Según contrato	Contratos
Aseguradora	Si hay ciberpóliza	Según póliza, normalmente inmediato	Póliza

Comprueba siempre la norma vigente. Los plazos de NIS2 dependen de cómo esté transpuesta en España en el momento de aplicarla, y los sectores regulados (financiero, sanitario, infraestructuras críticas) tienen obligaciones propias.

2.1. ¿Es una brecha de datos personales?

Lo es cuando se destruyen, pierden, alteran, comunican o se accede sin autorización a datos personales. Tres ejemplos: un ransomware que cifra la base de clientes (aunque se recupere), un correo con datos enviado a un destinatario equivocado y un portátil sin cifrar perdido.

No se notifica a la AEPD solo si es improbable que la brecha suponga un riesgo para las personas, y esa valoración hay que dejarla documentada. En todo caso, la organización debe llevar un registro interno de todas las brechas.

2.2. El reloj

Las 72 horas empiezan cuando la organización tiene constancia de la brecha, no cuando termina la investigación. Si aún no se sabe todo, se hace una notificación inicial y se completa después.

3. Qué contiene una notificación

3.1. A un CSIRT

- Datos de contacto y de la organización.
- Fecha y hora de detección y, si se conoce, de inicio.
- Descripción de lo ocurrido.
- Clasificación según la taxonomía, peligrosidad e impacto.
- Sistemas y servicios afectados.
- Medidas adoptadas hasta el momento.
- Indicadores de compromiso disponibles.
- Si hay afectación a otras organizaciones o países.

Se envía por el canal que indica cada organismo (formulario o correo; en INCIBE-CERT, incidencias@incibe-cert.es) y se actualiza conforme avanza el caso.

3.2. A la AEPD

Se presenta por el formulario de su sede electrónica e incluye:

- Naturaleza de la brecha.
- Categorías y número aproximado de personas y de registros afectados.
- Contacto del delegado de protección de datos.
- Posibles consecuencias.
- Medidas adoptadas o propuestas.

3.3. A las personas afectadas

En lenguaje claro: qué ha pasado, qué datos suyos están afectados, qué puede ocurrirles, qué ha hecho la organización y qué pueden hacer ellas (cambiar contraseñas, vigilar movimientos bancarios, desconfiar de mensajes que usen esos datos).

4. Comunicación de incidentes

4.1. Comunicación interna

- Un canal único y conocido para avisar: buzón, teléfono o botón de reporte.
- Escalado definido: quién avisa a quién según la gravedad.
- Durante el incidente, un canal alternativo por si el correo o la mensajería corporativa están comprometidos.
- Información a la plantilla: qué ocurre, qué deben hacer y qué no, y a quién dirigir las preguntas.
- Actualizaciones periódicas a la dirección, breves y en términos de negocio.

4.2. Comunicación externa

- Un único portavoz y mensajes aprobados.
- Hechos confirmados, sin especular ni minimizar.
- Qué se está haciendo y qué deben hacer los afectados.
- Coherencia entre lo que se dice a clientes, medios, reguladores y empleados.
- Nada de detalles técnicos que ayuden al atacante.

4.3. Errores típicos

Negar o tardar, culpar al empleado o al proveedor, usar jerga, prometer que «no volverá a ocurrir» y dar cifras que luego hay que corregir al alza.

5. Dominios web y phishing

El phishing es el incidente que más se notifica, y analizarlo empieza casi siempre por un dominio.

5.1. Anatomía de un dominio

En acceso.banco-ejemplo.es, el dominio de primer nivel es .es, el dominio registrado es banco-ejemplo.es y acceso es un subdominio. La regla para leer una URL: lo que manda es lo que hay justo antes de la primera barra, leído de derecha a izquierda. En banco-ejemplo.es.clientes-seguro.com/login, el dominio real es clientes-seguro.com.

5.2. Tipos de dominios

- Genéricos (.com, .org, .net) y nuevos genéricos (.shop, .online, .xyz), baratos y frecuentes en fraudes.
- Geográficos (.es, .fr, .eu).

5.3. Trucos habituales

- **Typosquatting:** errores de tecleo o letras parecidas (paypa1.com, rnicrosoft.com).
- **Homógrafos:** caracteres de otros alfabetos idénticos a la vista.
- **Subdominios engañosos**, como en el ejemplo anterior.
- **Acortadores y redirecciones** que ocultan el destino.
- El candado solo indica que la conexión va cifrada, no que el sitio sea legítimo.

6. Detectar y verificar un phishing

6.1. Señales en el mensaje

- Remitente que no coincide con la entidad, o dominio parecido.
- Urgencia, amenaza o premio.
- Enlace cuyo destino real no corresponde con el texto.
- Adjuntos inesperados, sobre todo comprimidos, ofimáticos con macros o HTML.
- Petición de credenciales, datos bancarios o códigos.

La ortografía ya no es una señal fiable: los mensajes generados con inteligencia artificial están bien escritos.

6.2. Herramientas de verificación

- **WHOIS / RDAP:** fecha de registro, registrador y servidores de nombres. Un dominio registrado hace tres días que dice ser un banco no necesita más análisis.
- **Cabeceras del correo:** resultado de SPF, DKIM y DMARC, y servidores por los que ha pasado.
- **VirusTotal y urlscan.io:** reputación y captura de la página sin visitarla.
- **Registros DNS:** dónde apunta el dominio.

```
whois dominio-sospechoso.com
dig +short dominio-sospechoso.com
dig +short TXT _dmarc.empresa.es
```

Precaución: los enlaces sospechosos no se abren desde el equipo de trabajo. Se analizan con servicios en línea o en una máquina aislada.

6.3. Dónde reportarlo

- Internamente, al equipo de seguridad, con el mensaje original adjunto (no reenviado, para conservar las cabeceras).
- A INCIBE-CERT, y la ciudadanía también a través del 017.
- A la entidad suplantada.
- Al registrador y al proveedor de alojamiento del dominio fraudulento, para pedir su retirada.
- A las fuerzas de seguridad si hay perjuicio económico.

7. Ejemplos frecuentes

- **Cuenta suspendida:** «Hemos bloqueado su cuenta; verifique sus datos en 24 horas». Busca credenciales.
- **Confirmación de pedido o entrega:** un paquete pendiente con un pequeño pago de aduanas. Busca datos de tarjeta.
- **Devolución de impuestos:** suplanta a la Agencia Tributaria en campaña de la renta.
- **Factura pendiente:** adjunto malicioso dirigido a administración.
- **Buzón lleno o documento compartido:** falsa página de inicio de sesión corporativa.

En todos, el patrón es el mismo: una marca conocida, un motivo creíble, una urgencia y un enlace.

Para ampliar

- Guía Nacional de Notificación y Gestión de Ciberincidentes.
- AEPD: guía para la notificación de brechas de datos personales y herramienta Asesora Brecha.
- Reglamento (UE) 2016/679 (RGPD), artículos 33 y 34.
- Directiva (UE) 2022/2555 (NIS2).
- INCIBE: avisos de seguridad y línea de ayuda 017.